

Document: auditq_upload.pdf
Generated: 12 June 2026 03:31
Model: Qwen/Qwen2.5-7B-Instruct
Embeddings: BAAI/bge-small-en-v1.5 | FAISS IndexFlatIP

69.5%

MEDIUM

OVERALL COMPLIANCE SCORE

69.5%

Risk Level: MEDIUM | Rules Checked: 18 | Tokens: 6928 | Avg Latency: 9.07s/chunk

COMPLIANCE SCORE BY FRAMEWORK

GDPR		55.0%
SOX		28.6%
HIPAA		75.0%
PCI DSS		100.0%
Insurance Compliance		100.0%

VALIDATION STATUS SUMMARY

11

COMPLIANT

4

NON-COMPLIANT

3

PARTIAL

0

NOT APPLICABLE

DETAILED COMPLIANCE FINDINGS

GDPR

GDPR-002

PART

HIG

75%

The document mentions interim retention periods but lacks a formal, approved data retention schedule.

Evidence: However, the Company acknowledges that a comprehensive, documented data retention schedule covering all data categories has not yet been formally approved by the Data Protection Officer.

Gap: A formal, documented data retention schedule covering all data categories is missing.

Action: Develop and approve a formal data retention schedule for all data categories.

GDPR-005

PASS

MED

100%

The document references the existence of a compliance addendum which implies a data processing agreement is in place.

Evidence: This agreement covers compliance obligations under GDPR, SOX, HIPAA, PCI-DSS, and Insurance/Financial Services regulations applicable to GlobalFinTech Corp.

GDPR-004

PASS

CRI

100%

The document clearly states the 72-hour reporting timeline.

Evidence: The Company will assess the risk to data subjects and notify the relevant supervisory authority (ICO in the UK) within 72 hours of becoming aware of the breach where the breach is likely to result in a risk to the rights...

GDPR-005

PART

MED

85%

While most third-party data processors have agreements, some are still lacking.

Evidence: Data Processing Agreements (DPAs) compliant with Article 28 of GDPR have been executed with 39 of these processors. Eight processors, primarily recent onboarding during Q4 2025, do not yet have executed DPAs in place.

Gap: DPAs are not in place for 8 third-party processors.

Action: Complete the execution of DPAs with the remaining 8 third-party processors by Q2 2026.

GDPR-004

FAIL

CRI

0%

There is no mention of a breach notification procedure with a 72-hour reporting timeline.

Evidence: No relevant evidence found in the provided document.

Gap: A breach notification procedure with 72-hour reporting timeline is missing.

Action: Implement a breach notification procedure that includes a 72-hour reporting timeline to the supervisory authority.

SOX

SOX-003

FAIL

HIG

80%

The document does not explicitly state a 7-year financial record retention policy.

Evidence: Customer transaction records are retained for 7 years to satisfy financial regulatory requirements.

Gap: A 7-year financial record retention policy must be explicitly stated.

Action: Explicitly state a 7-year financial record retention policy in the document.

SOX-001

FAIL

CRI

70%

ICFR documentation is not fully completed.

Evidence: Management acknowledges that formally documented Internal Controls over Financial Reporting (ICFR) as required under Section 404 of the Sarbanes-Oxley Act have not been comprehensively documented for the current fiscal y...

Gap: ICFR documentation is not fully completed.

Action: Complete the ICFR documentation by Q3 2026.

SOX-003

PASS

HIG

100%

Evidence: All financial records, general ledger entries, accounts payable and receivable records, bank reconciliations, audit workpapers, and supporting documentation are retained for a minimum period of 7 years in accordance with...

HIPAA

HIPAA-004 **PASS** **HIG**  100%

The document mentions logging and monitoring of PHI access.

Evidence: All PHI access is logged and monitored by the Information Security team.

HIPAA-003 **PASS** **CRI**  100%

The document specifies the 60-day notification requirement.

Evidence: In the event of a breach of unsecured PHI, the Company will notify affected individuals without unreasonable delay and within 60 days

HIPAA-003 **PASS** **CRI**  100%

The document explicitly states the 60-day notification procedure.

Evidence: Notification to the Secretary of HHS will be provided simultaneously. For breaches affecting 500 or more individuals in a state, prominent media notice will be provided.

HIPAA-004 **PART** **HIG**  85%

Audit logging is partially compliant as it is only in place for one system.

Evidence: Audit logs are in place for the primary Workday HR system, however three legacy occupational health record systems acquired through the 2023 merger with MedCorp Solutions do not currently generate HIPAA-compliant audit l...

Gap: Audit logging is not in place for all systems containing PHI.

Action: Implement HIPAA-compliant audit logging for all systems containing PHI.

HIPAA-005 **FAIL** **HIG**  70%

Business Associate Agreements are not in place with all vendors who handle PHI.

Evidence: The Company maintains a register of all Business Associates updated quarterly. Business Associate Agreements have not been executed with two recently onboarded employee assistance programme providers who may have access ...

Gap: BAAs are not in place with two recently onboarded employee assistance programme providers.

Action: Execute signed BAAs with the two recently onboarded employee assistance programme providers within 30 days.

PCI DSS

PCI-003 **PASS** **HIG**  95%

The document provides sufficient evidence of firewall and network segmentation practices.

Evidence: The cardholder data environment is segregated from the corporate network and public internet using a dedicated next-generation firewall (Palo Alto Networks PA-5220) with application-aware filtering. Network segmentation ...

PCI-002 **PASS** **HIG**  98%

The document clearly states that access is restricted to those whose job roles require it, aligning with the principle of least privilege.

Evidence: is restricted exclusively to staff whose job roles require such access, in accordance with the principle of least privilege.

PCI-004 **PASS** **HIG**  97%

Evidence:

The Company conducts quarterly internal and external vulnerability scans of all systems in scope for PCI-DSS using Qualys Enterprise. Critical and high vulnerabilities are remediated within 30 and 60 days respectively. A...

Insurance Compliance

INS-003

PASS

CRI

100%

The document explicitly mentions AML and KYC procedures.

Evidence:

5.3 Anti-Money Laundering and KYC Compliance The Company operates a risk-based AML programme compliant with the Money Laundering, Terrorist Financing and Transfer of Funds Regulations 2017.

INS-004

PASS

CRI

100%

The document states the company's adherence to Solvency II Directive and provides coverage ratios.

Evidence:

5.4 Capital Adequacy and Solvency Requirements The Company maintains regulatory capital in accordance with the Solvency II Directive as implemented in UK law post-Brexit.

RISK-RANKED REMEDIATION ACTION PLAN

Issues are ranked by severity. Address CRITICAL items immediately, HIGH within 30 days, MEDIUM within 90 days.

1	SOX-001	SOX	CRITICAL	NON COMPLIAN	Gap: ICFR documentation is not fully completed. Action: Complete the ICFR documentation by Q3 2026.
2	GDPR-004	GDPR	CRITICAL	NON COMPLIAN	Gap: A breach notification procedure with 72-hour reporting timeline is missing. Action: Implement a breach notification procedure that includes a 72-hour reporting timeline to the supervisory authority.
3	GDPR-002	GDPR	HIGH	PARTIAL	Gap: A formal, documented data retention schedule covering all data categories is missing. Action: Develop and approve a formal data retention schedule for all data categories.
4	SOX-003	SOX	HIGH	NON COMPLIAN	Gap: A 7-year financial record retention policy must be explicitly stated. Action: Explicitly state a 7-year financial record retention policy in the document.
5	HIPAA-004	HIPAA	HIGH	PARTIAL	Gap: Audit logging is not in place for all systems containing PHI. Action: Implement HIPAA-compliant audit logging for all systems containing PHI.
6	HIPAA-005	HIPAA	HIGH	NON COMPLIAN	Gap: BAAs are not in place with two recently onboarded employee assistance programme providers. Action: Execute signed BAAs with the two recently onboarded employee assistance programme providers within 30 days.
7	GDPR-005	GDPR	MEDIUM	PARTIAL	Gap: DPAs are not in place for 8 third-party processors. Action: Complete the execution of DPAs with the remaining 8 third-party processors by Q2 2026.